GMC LANKA CREATIONS

OWASP Top 10 Compliance Evidence

SENG 34213 – System Development Project

By

KEERTHI GOPALAVANNAN

SE/2021/020

ASWINI PARAMESWARAN

SE/2021/023

BALASUBRAMANIYAM THUSHAKARAN

SE/2021/052

THARSHANA SARATHCHANDAR

SE/2021/056

A report submitted in partial fulfillment of the requirements for the degree of Bachelor of Science Honors in Software Engineering (B. Sc.SE)

Name of the Supervisor: Dr. Nalin Warnajith

Software Engineering Teaching Unit

Faculty of Science

University of Kelaniya

Sri Lanka

2026

Version history

Version No.	Date	Author	Summary of Changes
01	2026/10/24	Team	Compliance review of release 0.1.1

Table of Contents

CHAPTER 1 INTRODUCTION 1

1.1 A01 – Broken Access Control 1

1.2 A02 – Cryptographic Failures 1

1.3 A03 – Injection 2

1.4 A04 – Insecure Design 2

1.5 A05 – Security Misconfiguration 3

1.6 A06 – Vulnerable and Outdated Components 3

1.7 A07 – Identification and Authentication Failures 3

1.8 A08 – Software and Data Integrity Failures 4

1.9 A09 – Security Logging and Monitoring Failures 4

1.10 A10 – Server-Side Request Forgery 5

CHAPTER 2 CODE QUALITY GATES 6

(Right-click and choose Update Field to refresh the table of contents and page numbers.)

CHAPTER 1 INTRODUCTION

This document provides the evidence required by guideline Section 8.1 that the OWASP Top 10 (2021) risks were addressed in the implementation of GMC Lanka Creations. For each risk it lists the controls in place, where they are implemented, the automated tests that verify them, the remaining gaps and the planned actions. All tests referred to passed in the run of 24 October 2026; 36 API integration test executions verify access control directly.

Table 1.1: Compliance overview

ID	Risk	Status
A01	Broken Access Control	Addressed
A02	Cryptographic Failures	Addressed
A03	Injection	Addressed
A04	Insecure Design	Addressed
A05	Security Misconfiguration	Addressed
A06	Vulnerable and Outdated Components	Addressed
A07	Identification and Authentication Failures	Addressed
A08	Software and Data Integrity Failures	Addressed
A09	Security Logging and Monitoring Failures	Addressed
A10	Server-Side Request Forgery	Addressed

1.1 A01 – Broken Access Control

Field	Content
Status	Addressed
Controls	Role rules for every route group in SecurityConfig (ADMIN, CUSTOMER, TECHNICIAN); @PreAuthorize on product write endpoints; ownership checks return 404 for other customers' orders and appointments; React route guards.
Implementation	config/SecurityConfig.java; controller/ProductController.java (@PreAuthorize); service.impl/OrderServiceImpl and AppointmentServiceImpl (ownership checks); frontend src/App.jsx (ProtectedRoute)
Verifying tests	AdminControllerIT.adminEndpoints_withCustomerToken_return403 (10 endpoints); adminEndpoint_withTechnicianToken_returns403; OrderControllerIT.getOrder_anotherCustomersOrder_returns404; ProductControllerIT.create_asCustomer_returns403
Remaining gaps	None identified.
Planned action	—

1.2 A02 – Cryptographic Failures

Field	Content

Field	Content
Status	Addressed
Controls	BCrypt strength 12; refresh and password-reset tokens stored only as SHA-256 hashes; JWT signed with HS256 and a ≥256-bit secret from the JWT_SECRET environment variable; HTTPS terminated by Caddy with automatic Let's Encrypt certificates; Stripe Elements keeps card data off GMC Lanka servers.
Implementation	config/PasswordConfig.java (BCryptPasswordEncoder(12)); service.impl/RefreshTokenServiceImpl and PasswordResetServiceImpl (SHA-256 token hashes); security/JwtTokenProvider.java; infra deploy/Caddyfile (HTTPS); components/payment/StripePaymentForm.jsx
Verifying tests	JwtTokenProviderTest; PasswordResetServiceImplTest (token stored hashed)
Remaining gaps	If JWT_SECRET is missing, a random key is generated at start-up (sessions are lost on restart rather than being insecure).
Planned action	Make JWT_SECRET mandatory in production start-up checks.

1.3 A03 – Injection

Field	Content
Status	Addressed
Controls	All data access through Spring Data JPA derived and parameterised queries; Jakarta Bean Validation on every request DTO; React escapes rendered output; SVG uploads rejected.
Implementation	All repositories extend JpaRepository with derived queries; dto.request.* with Jakarta Validation; FileStorageServiceImpl rejects SVG
Verifying tests	OrderControllerIT.placeOrder_withInvalidPhoneOrMissingPaymentMethod_returns400; GlobalExceptionHandlerTest
Remaining gaps	None identified.
Planned action	—

1.4 A04 – Insecure Design

Field	Content
Status	Addressed
Controls	Security design in SDS Chapter 6. Prices calculated only on the server (CheckoutPricing); pessimistic row locks prevent overselling and double payment; payment amount and currency re-checked against Stripe with automatic refund on mismatch; unpaid card orders expire after 60 minutes. Gap: uploads are validated by extension and size, not by content.
Implementation	SDS Chapter 6 (security design); service/CheckoutPricing.java; @Lock(PESSIMISTIC_WRITE) in OrderRepository and ProductRepository; OrderServiceImpl payment verification; SchedulingConfig (unpaid order expiry)
Verifying tests	OrderControllerIT.confirmPayment_whenAmountDoesNotMatch_refundsInsteadOfMarkingPaid; placeOrder_whenStockRanOutAfterAddingToCart_returns422AndKeepsCart
Remaining	Upload validation by extension and size only; no formal threat model (STRIDE)

Field	Content
gaps	document.
Planned action	Validate file content type (magic bytes); document a threat model.

1.5 A05 – Security Misconfiguration

Field	Content
Status	Addressed
Controls	server.error.include-stacktrace=never and include-message=never; uniform error body without internal detail; nginx sends X-Content-Type-Options, X-Frame-Options DENY and Referrer-Policy and hides its version; non-root container user; no default credentials (all secrets from environment). Gap: Swagger UI is reachable without login in production and no Content-Security-Policy header is sent.
Implementation	application.properties (server.error.include-stacktrace=never, include-message=never); exception/GlobalExceptionHandler.java; infra docker/frontend/nginx/default.conf.template (security headers, server_tokens off); backend image runs as non-root user
Verifying tests	GlobalExceptionHandlerTest; Infra/docker/frontend/nginx/default.conf.template
Remaining gaps	Swagger UI and /api-docs are public in production; no Content-Security-Policy or HSTS header.
Planned action	Disable springdoc in production; add CSP and HSTS headers in Caddy.

1.6 A06 – Vulnerable and Outdated Components

Field	Content
Status	Addressed
Controls	Trivy scans pom.xml dependencies and fails the build on HIGH or CRITICAL findings; npm audit --audit-level=high on the frontend; Dependabot raises monthly update PRs; two reviewed exceptions recorded in security/backend.trivyignore.yaml with an expiry date (2027-01-31).
Implementation	infra .github/workflows/backend-ci.yml (Trivy job); frontend-ci.yml (npm audit); .github/dependabot.yml; security/backend.trivyignore.yaml
Verifying tests	CI job 'Security Scan' (backend and frontend workflows)
Remaining gaps	Two accepted CVEs (Spring XsltView, view fragments) not reachable in a JSON-only API; review before 2027-01-31.
Planned action	Re-evaluate when upgrading Spring Boot.

1.7 A07 – Identification and Authentication Failures

Field	Content
Status	Addressed
Controls	Rate limiting of login, registration and password reset; rotating refresh tokens

Field	Content
	with reuse detection; password change and reset revoke all sessions; reset links single-use and valid 30 minutes; identical response for known and unknown emails. Gap: no account lockout after N failures and no MFA (see ADR-05).
Implementation	security/RateLimiter.java; controller/AuthController.java; RefreshTokenServiceImpl (rotation, reuse detection); UserServiceImpl (password change revokes sessions)
Verifying tests	AuthControllerIT.login_afterTenFailedAttempts_returns429; forgotPassword_forUnknownEmail_givesSameReplyAndSendsNothing; logout_invalidatesRefreshToken; UserControllerIT (password change revokes sessions)
Remaining gaps	No account lockout after N failed attempts; no MFA for administrators; rate-limit state is per instance.
Planned action	Add TOTP MFA for ADMIN; move limiter to Redis when scaling.

1.8 A08 – Software and Data Integrity Failures

Field	Content
Status	Addressed
Controls	package-lock.json and the Maven wrapper are committed; CI uses npm ci and npm audit signatures; Stripe webhooks verified with the Stripe-Signature header; images built only by CI and pulled by tag from GHCR.
Implementation	frontend package-lock.json, backend mvnw wrapper; CI npm ci / npm audit signatures; PaymentController (Webhook.constructEvent); deploy-ec2.sh pulls images by tag from GHCR
Verifying tests	PaymentControllerIT (webhook handling); CI 'Security Scan' job
Remaining gaps	None identified.
Planned action	—

1.9 A09 – Security Logging and Monitoring Failures

Field	Content
Status	Addressed
Controls	Payment, refund and e-mail failures are logged and administrators receive e-mail alerts for failed refunds. Gap: authentication events (login success/failure, token reuse) are not logged, the catch-all exception handler does not log, and there is no log retention (NFR016).
Implementation	@Slf4j logging in OrderServiceImpl, StripeGatewayImpl, EmailServiceImpl, PaymentController; admin alert e-mails for failed refunds
Verifying tests	—
Remaining gaps	Authentication events and authorisation failures are not logged; catch-all handler does not log; no log retention (NFR016). Logs do not contain passwords or tokens.
Planned action	Log authentication events without PII; ship container logs to CloudWatch with 12-month retention.

1.10 A10 – Server-Side Request Forgery

Field	Content
Status	Addressed
Controls	The server never fetches user-supplied URLs. Outbound calls go only to fixed hosts (Stripe API, SMTP). Meeting links entered by admins are validated as http/https and only stored and displayed.
Implementation	No server-side fetching of user URLs; AppointmentServiceImpl validates meeting links (http/https)
Verifying tests	AppointmentServiceImplTest (meeting link validation)
Remaining gaps	None identified.
Planned action	—

CHAPTER 2 CODE QUALITY GATES

Table 2.1: Code quality gates

Gate (guideline 8.2)	How it is enforced	Status
Zero linting errors on new or modified files	Checkstyle + Spotless (backend), ESLint + Prettier (frontend) in the Lint & Format job	Met – 0 errors (61 frontend warnings)
Unit test coverage on new code ≥ 80%	JaCoCo check on merged coverage; Vitest per-file thresholds	Met – 91.3% backend lines
No known high or critical vulnerabilities	Trivy and npm audit fail the pipeline	Met (2 reviewed exceptions)
All [blocker] PR comments resolved before merge	Pull-request review	Followed by the team
No merge to main without an approved review	Branch protection on main; production environment approval	Configured